

# Security Incident Report

CEO Account Takeover Investigation | Azure Data Explorer & KQL

|                     |                                                                                 |
|---------------------|---------------------------------------------------------------------------------|
| Report Type         | Simulated SOC Incident Investigation                                            |
| Environment         | Controlled training environment using synthetic data                            |
| Analyst             | Adam Shehayber                                                                  |
| Year                | 2026                                                                            |
| Severity Assessment | High - executive identity compromise with persistence and BEC staging           |
| Status              | Investigation completed; containment and remediation recommendations documented |

## 1. Executive Summary

This report documents a simulated investigation of an executive account takeover. Authentication and audit telemetry was analyzed in Azure Data Explorer using Kusto Query Language (KQL). The investigation identified anomalous Lagos-based sign-in activity against an executive account, a password-spray pattern across multiple identities, successful credential-based access, unauthorized MFA registration, and a malicious inbox rule consistent with business email compromise (BEC) staging. Scoping queries also identified successful activity affecting an additional account.

## 2. Investigation Method

- Reviewed the executive account's sign-in timeline and compared suspicious activity with the user's historical baseline.
- Aggregated failed authentications by source IP and distinct targeted accounts to identify password-spray behavior.
- Queried audit telemetry from suspicious infrastructure to identify post-compromise actions and persistence.
- Scoped successful authentications from attacker infrastructure to identify additional affected identities.
- Mapped observed behaviors to MITRE ATT&CK; and developed containment and remediation recommendations.

## 3. Key Findings

### Finding 1 - Suspicious executive sign-in was inconsistent with the established baseline

The executive account showed a normal pattern centered in London, United Kingdom. During the incident window, failed sign-ins from Lagos, Nigeria were followed by successful authentication and subsequent access. The timing, preceding failures, unfamiliar infrastructure, and contrast with the established London baseline supported a malicious-access determination.

### Finding 2 - Authentication failures were consistent with password spraying

Analysis of failed sign-ins showed Lagos-based infrastructure distributing attempts across many identities rather than repeatedly attacking one account. One observed source generated 48 failed authentications against 23 distinct accounts. This low-volume, many-account pattern is consistent with password spraying.

### Finding 3 - The attacker established persistence

Audit telemetry associated with suspicious infrastructure showed an authenticator application identified as 'Pixel 6' being registered to the compromised executive account. An attacker-controlled authentication method could preserve access after a password reset.

## Finding 4 - A malicious inbox rule indicated BEC staging

The investigation identified an inbox rule named 'RSS Subscriptions' designed to move or conceal finance and invoice-related messages. This behavior is consistent with business email compromise staging intended to hide financial communications from the legitimate user.

## Finding 5 - Incident scoping identified additional compromise

Successful authentications from the suspicious 102.89.x.x infrastructure were reviewed across the environment. The results showed successful access associated with more than the original executive identity, demonstrating the need to scope beyond the first detected victim.

## 4. Indicators of Compromise

| Type       | Indicator         | Context                                                  |
|------------|-------------------|----------------------------------------------------------|
| IPv4       | 102.89.44.17      | Password-spray activity and executive account access     |
| IPv4       | 102.89.44.23      | Password-spray source                                    |
| IPv4       | 102.89.45.101     | Password-spray activity and additional successful access |
| MFA device | Pixel 6           | Unauthorized authenticator registration                  |
| Inbox rule | RSS Subscriptions | Finance/invoice email concealment                        |

## 5. MITRE ATT&CK; Mapping

| Tactic            | Technique                                 | ID        |
|-------------------|-------------------------------------------|-----------|
| Credential Access | Brute Force: Password Spraying            | T1110.003 |
| Initial Access    | Valid Accounts                            | T1078     |
| Persistence       | Account Manipulation: Device Registration | T1098.005 |
| Defense Evasion   | Hide Artifacts: Email Hiding Rules        | T1564.008 |

## 6. Recommended Containment and Remediation

- Revoke active sessions and refresh tokens for confirmed compromised identities.
- Reset credentials after active sessions have been revoked.
- Remove unauthorized MFA authentication methods and review all registered authentication factors.
- Delete malicious mailbox rules and audit affected mailboxes for additional forwarding or hiding rules.
- Block known attacker infrastructure where appropriate and monitor for related indicators.
- Review all targeted identities for successful access and require precautionary resets where risk warrants.
- Require MFA and strengthen Conditional Access controls, especially for unusual geographies and executive accounts.
- Deploy password-spray detections based on failures per source IP across distinct identities in a rolling time window.
- Alert on unexpected MFA method registration and suspicious inbox-rule creation.

## 7. Lessons Learned

The investigation demonstrated that a suspicious login should be treated as the beginning of the analysis rather than the end. Correlating sign-in and audit telemetry made it possible to reconstruct the attack path from credential attacks to successful access, persistence, and BEC staging. Baseline comparison helped separate true compromise from unusual-but-legitimate activity, while environment-wide scoping exposed additional impact that would have been missed by investigating only the original alert.

## Disclaimer

This report is a portfolio artifact based on a controlled cybersecurity training exercise using synthetic data. The organization, identities, IP addresses, and incident details are fictional and are presented solely to demonstrate SOC investigation, KQL, threat hunting, and incident-response skills.